

Aufgabenheft

Tag 12

RPA skalieren ohne Kontrollverlust –
Governance, Audit Trail, Security
und Change in elf Aufgaben.

11 Aufgaben · L1 · L2 · L3

Niveau-Mix:
3 L1 · 5 L2 · 3 L3

Bearbeitung:
Selbstbearbeitung im Lernpfad

Dozent:
Can Siebert

Begleitend:
Lehrskript & Lösungsheft

So arbeiten Sie mit diesem Heft

Dieses Aufgabenheft enthält elf Aufgaben zu Tag 12 – *RPA skalieren ohne Kontrollverlust*: Bot-Governance, Audit Trail, Exception Handling, Security by Design und Change Management. Die Aufgaben sind in drei Niveaus gegliedert:

- **L1 • Wissen** – **Wissen.** Lifecycle, Rollen, Standards, Exception-Typen. 5 – 10 Minuten.
- **L2 • Anwendung** – **Anwendung.** RACI, Audit-Log, Playbooks, Security-Guardrails, Change-Paket. 15 – 30 Minuten.
- **L3 • Management** – **Management.** Operating Model, Risk Appetite, Anti-Gaming-KPIs. 30 – 45 Minuten.

Jede Aufgabe enthält eine Niveau-Markierung, einen Zeit-Richtwert, den Aufgabentext, einen Antwort-Freiraum und eine *YouTube-Suchquery* für den begleitenden Lernpfad.

Hinweis

Die Musterlösungen finden Sie im separaten *Lösungsheft Tag 12*. *Governance ist kein Selbstzweck* – sie ist die Bedingung, dass Skalierung verantwortbar bleibt. Versuchen Sie jede Aufgabe zuerst eigenständig.

Niveau L1 – Wissen & Reproduktion

Hilfsvideos zu diesem Tag

Die folgenden YouTube-Erklärvideos vermitteln die Inhalte, die Sie zur Bearbeitung der Aufgaben benötigen. Klicken Sie auf den Titel, um das Video direkt zu öffnen; die vollständige URL steht in Klammern.

1. Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

<https://youtu.be/jOpgFmyz70Y>

(URL: <https://youtu.be/jOpgFmyz70Y>)

2. Change Management mit ADKAR — Veränderung als Lernreise

<https://youtu.be/3LczBH3PXdw>

(URL: <https://youtu.be/3LczBH3PXdw>)

3. Widerstand gegen Veränderung produktiv machen

<https://youtu.be/9zTC87rzeI8>

(URL: <https://youtu.be/9zTC87rzeI8>)

Tipp: Öffnen Sie das Video, lassen Sie es im Hintergrund laufen und arbeiten Sie parallel an der Aufgabe.

Aufgabe 1 – Bot-Lifecycle & Governance-Rollen

L1 • Wissen

~ 8 min

Der Bot-Lifecycle umfasst neun Phasen: *Idea* → *Assessment* → *Design* → *Build* → *Test* → *Deploy* → *Run* → *Improve* → *Retire*. Mindestens sieben Rollen sind beteiligt: *Process Owner*, *Bot Owner*, *Developer*, *Reviewer/QA*, *Security Owner*, *Operations/Run*, *Change Owner* (Fachbereich).

Arbeitsauftrag:

1. Ordnen Sie jeder der **neun Lifecycle-Phasen** jeweils die *primär verantwortliche* Rolle zu (eine Rolle kann mehrere Phasen abdecken).
2. Erklären Sie in je einem Satz, was in den Phasen *Assessment*, *Test* und *Retire* konkret entschieden / produziert wird.
3. Nennen Sie **zwei Risiken**, die entstehen, wenn die Phase *Improve* ausgelassen wird (Live-Bots ohne kontinuierliche Verbesserung).

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Aufgabe 2 – Vier nicht verhandelbare Governance-Standards

L1 • Wissen

~ 8 min

Ein *Governance-Minimum* besteht laut Lehrskript aus fünf Bausteinen: *Rollen + Freigaben + Standards + Monitoring + Incident-Prozess*. Bei den Standards lassen sich vier Bereiche kaum verhandeln: *Naming & Versionierung, Logging-Minimum, Exception Codes, Freigabe vor Produktion*.

Arbeitsauftrag:

1. Beschreiben Sie jeden der vier Standards in 2–3 Sätzen so, dass eine neue Entwicklerin ihn unmittelbar anwenden kann (z. B. Naming-Konvention: `<Domain>_<Prozess>_<Action>_v<Major>.<Minor>`).
2. Markieren Sie für jeden Standard die *Konsequenz bei Verletzung* (z. B. “Bot ohne Logging-Minimum geht nicht in Prod – hartes Stop-Kriterium”).
3. Ergänzen Sie einen **fünften** Standard, den Sie aus Ihrer Erfahrung als ebenso nicht verhandelbar einstufen, und begründen Sie warum.

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Aufgabe 3 – Exception-Typen & Audit-Trail-Felder

L1 • Wissen

~ 10 min

Ausnahmen lassen sich in drei Typen sortieren: *Business Exceptions* (fachlich – z. B. *ApprovalRequired*, *DuplicateInvoice*), *System Exceptions* (technisch – *ERPDn*, *Timeout*) und *Data Exceptions* (Qualität – *MissingCostCenter*, *UnknownVendor*). Ein vollständiger Audit Trail beantwortet fünf Fragen: *Wer / Was / Wann / Womit / Ergebnis* – plus optional *Begründung*.

Arbeitsauftrag:

1. Erstellen Sie eine **Tabelle** mit den drei Exception-Typen und je drei konkreten Beispielen aus den Domänen *Rechnungsverarbeitung*, *HR-Onboarding*, *Bestellabwicklung*.
2. Skizzieren Sie ein **Audit-Log-Template** mit mindestens neun Feldern (z. B. *BotID*, *Version*, *InputRef*, *Action*, *TargetSystem*, *ResultStatus*, *ExceptionCode*, *ProcessedBy*, *Timestamp*).
3. Markieren Sie, welche drei Felder *unbedingt unveränderbar* (append-only) gespeichert werden müssen – und warum.

Hinweis: Das Prinzip “fail safe” bedeutet *kontrollierter Abbruch* mit Übergabe an einen Menschen (Queue/Task) und vollständiger Nachweisführung – nicht stilles Steckenbleiben.

Lernvideo: [Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA](#)

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Niveau L2 – Anwendung & Transfer

Aufgabe 4 – Governance-Minimum in 45 Minuten

L2 • Anwendung

~ 30 min

Ausgangslage: “KMU mit RPA-Wildwuchs”

Unternehmen: “Nordhandel AG” – mittelständischer Distributor mit 14 Live-Bots in 4 Fachbereichen.

Problem: RPA wächst schnell, jeder baut Bots “wie er will”. Vor zwei Wochen gab es einen Vorfall: ein Bot hat *falsche Daten* ins ERP gebucht, niemand weiß, welche Version lief. Keine zentrale Logging-Pflicht, keine Freigabe vor Prod, keine RACI.

Auftrag der Geschäftsleitung: Innerhalb von 45 Minuten ein *1-Seiten-Governance-Minimum* liefern – so knapp, dass es alle lesen, aber so verbindlich, dass es Wirkung entfaltet.

Arbeitsauftrag:

1. **RACI für 6 Rollen** (Process Owner, Bot Owner, Developer, Reviewer/QA, Security, Operations) über fünf typische Tätigkeiten: *Bot-Idee bewerten, Code reviewen, Freigabe vor Prod erteilen, Run & Monitoring, Incident bearbeiten*.
2. **Vier nicht verhandelbare Standards** (z. B. Versionierung, Logging-Minimum, Exception Codes, Freigabe vor Prod) – je 1 – 2 Sätze konkret.
3. **Release Flow Build** → *Test* → *UAT* → *Deploy* → *Monitoring* mit zwei Gates (vor UAT, vor Deploy): wer entscheidet was?
4. **Fast-Track-Regel für kleine Bots:** Welche Klasse von Bots darf einen verkürzten Weg nehmen? Welche *Guardrail* (z. B. kein PII, max. 100 Transaktionen/Tag, kein Schreibzugriff auf Finance-Systeme) bleibt verpflichtend?

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Aufgabe 5 – Audit Trail Standard & fünf Exception-Playbooks

L2 • Anwendung

~ 25 min

Szenario: Rechnungsbot mit Ausnahmen

Bot: *InvoiceBot* v2.3 verarbeitet eingehende Rechnungen aus dem Lieferantenportal in das ERP.

Beobachtete Ausnahmen (Top 5):

1. *MissingCostCenter*: Rechnung ohne Kostenstelle.
2. *DuplicateInvoice*: Rechnungsnummer existiert bereits im ERP.
3. *ERPNotReachable*: ERP-System lässt sich nicht ansprechen.
4. *ApprovalThreshold*: Betrag übersteigt 10.000 € – Vier-Augen-Freigabe nötig.
5. *PortalUIChanged*: Selektor auf Lieferantenportal greift nicht mehr.

Arbeitsauftrag:

1. Definieren Sie das **Audit-Log-Template** (Felder, Datentypen, Pflicht/Optional). Mindestens 10 Felder; mind. drei davon *append-only*. Ergänzen Sie eine **Aufbewahrungs-Regel** (z. B. 5 Jahre für Finance-Logs, role-based Access).
2. Schreiben Sie für *jede* der fünf Exceptions ein **Playbook** (max. 4 Zeilen): *Owner*, *Reaktion* (Retry / Queue / Ticket / Eskalation), *SLA*, *Eskalationsweg*.
3. Formulieren Sie **zwei KPIs**, mit denen Sie die Wirksamkeit des Exception Handling steuern (z. B. *Exception Rate* $\leq 12\%$, *MTTR* < 4 h). Definieren Sie für jede KPI einen *Anti-Gaming-Mechanismus*.

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

This image shows a full page of white paper with horizontal dashed lines, typical of primary school handwriting practice paper. The lines are evenly spaced and run across the entire width of the page. There are no margins, text, or other markings present.

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Aufgabe 7 – Change-Paket für Mitarbeitende “hinter dem Bot”

L2 • Anwendung

~ 20 min

Fall: "Was passiert mit meinem Job?"

Team Rechnungseingang (12 Mitarbeitende) erfährt vom geplanten *InvoiceBot*. Reaktionen reichen von “endlich keine Tipptätigkeit mehr” über “mache ich überhaupt noch was?” bis hin zu offener Ablehnung (“ich werde diesen Bot nicht trainieren”). Die Bereichsleitung sagt öffentlich: “Es wird keine Entlassungen geben” – intern wird aber über 2 Stellen weniger im nächsten Budgetzyklus gesprochen.

Arbeitsauftrag:

1. **Rollenwandel** (3 Sätze): Wie verändert sich die Tätigkeit von “Erfassen” zu “Überwachen / Entscheiden / Exceptions bearbeiten”? Welche *neuen* Skills braucht das Team?
2. **Kommunikations-Botschaft**: Formulieren Sie eine zwei-Sätze-Kernbotschaft, die *glaubwürdig* ist (keine Schein-Garantie “alles bleibt wie es ist”), aber den Nutzen klar macht (“Bot nimmt Aufgaben, nicht Würde”).
3. **Trainingspfad**: Skizzieren Sie ein Curriculum in drei Stufen (*Operator – Owner – Champion*) mit je zwei Lerninhalten und einem Wirksamkeitsnachweis (z. B. “Operator löst 3 Standard-Exceptions selbstständig”).
4. **Umgang mit aktivem Widerstand**: Wie reagieren Sie konkret auf die Aussage “Ich werde diesen Bot nicht trainieren”? Drei Schritte: *Zuhören – Reframe – klare Konsequenz*.
5. **Drei Frühwarnsignale**, dass das Change-Programm scheitert (z. B. Krankenstand steigt, Bot-Vorschläge sinken, Exceptions werden bewusst eskaliert).

Lernvideo: Change Management mit ADKAR — Veränderung als Lernreise

[illegible]

.....

.....

.....

.....

.....

.....

Aufgabe 8 – Fallstudie “PharmaDistrib” – Rollout im regulierten Umfeld

L2 • Anwendung

~ 40 min

Fallstudie: PharmaDistrib

Unternehmen: “PharmaDistrib AG” – pharmazeutischer Distributor (reguliert, auditkritisch – GxP-relevante Prozesse).

Auftrag: RPA-Rollout in *Finance* und *Supply Chain* – 10 Bots in 3 Monaten.

Spannungsfeld:

- Auditoren fordern *Traceability* (jede Aktion nachweisbar).
- Security fordert *strenge Controls* (kein Self-Service, SoD strikt).
- Fachbereiche drängen auf *Speed* (“wir müssen liefern”).
- Erste Pilotbots laufen, aber Portal-UIs ändern sich, Exceptions steigen, Mitarbeitende sind verunsichert.

Restriktionen:

- 10 Wochen bis zum nächsten Audit-Sampling.
- Budget: 160.000 €.
- Begrenzte Security-Kapazität (1,5 FTE).
- Datenklassifikation *noch unklar*.

Arbeitsauftrag:

1. **Minimum Viable Governance:** Definieren Sie Lifecycle, Rollen (RACI über 6 Rollen), Release Gates (risikobasiert: Low-/Medium-/High-Risk Bot).
2. **Audit Trail Standard:** Welche Felder werden für GxP-Auditierbarkeit gefordert? Wer darf Logs *sehen* (Role-based Access)? Aufbewahrung (z. B. 5 Jahre)? Exportfähigkeit für Auditor?
3. **Exception Governance:** *Drei* Exception-Kategorien (Data / Business / System / Security) mit insgesamt *fünf* konkreten Playbooks (je Owner, Reaktion, SLA, Eskalation). *Zwei* KPIs (Exception Rate, MTTR) inkl. Schwellen.
4. **Security-by-Design Guardrails:** Account-Konzept, Secrets, SoD-Regeln, Logging-Integrität (append-only), PII-Behandlung.
5. **Change-Paket:** Kernbotschaft, Rollenwandel, Trainingsplan, Umgang mit Widerstand, Champions-Netzwerk.
6. **Prioritätenempfehlung:** Welche *drei* Bausteine starten Sie in den ersten 4 Wochen, welche 2 verschieben Sie bewusst – mit Begründung?

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

.....

.....

.....

This image shows a full page of white paper with horizontal ruling lines. The lines are evenly spaced and extend across the width of the page. There are no margins, text, or other markings on the paper.

Niveau L3 – Management & Entscheidungsarchitektur

Aufgabe 9 – Risk Appetite & Bot-Klassifikation

L3 • Management

~ 35 min

Rolle: Chief Risk Officer

Ihre Rolle: CRO eines mittelgroßen Konzerns (5.000 MA, mehrere Bereiche, eigene Automation CoE).

Ausgangslage: 60 Live-Bots, ca. 30 in der Pipeline. Bisher gibt es *keinen* formalen *Risk Appetite* für RPA. Der Vorstand fragt: “Wann sagen wir eigentlich *Nein*? Wo erlauben wir bewusst Risiko?”

Auftrag: Entwerfen Sie ein *Risk Appetite Framework* für RPA – schriftlich, freigabefähig.

Arbeitsauftrag:

1. **Bot-Klassifikation in drei Stufen** (*Low / Medium / High Risk*). Definieren Sie *vier* Kriterien (z. B. Transaktionswert, Datensensitivität, regulatorische Relevanz, Reversibilität) mit jeweils Schwellenwerten.
2. **Freigabestufen je Klasse:** Wer freigibt, welche Reviews verpflichtend sind, welche *Human-in-the-Loop*-Pflicht greift.
3. **SoD-Regeln:** Welche *drei* Trennungen sind klassenübergreifend zwingend? Bei welchen erlauben Sie Ausnahmen – unter welchen Bedingungen?
4. **Logging & Retention Standard:** Differenziert nach Klasse (z. B. Low = 1 Jahr, Medium = 3 Jahre, High = 7 Jahre) – mit Begründung.
5. **Zwei Entscheidungen unter Unsicherheit:** Für welche Bot-Klasse *erlauben* Sie *Fast Track*, obwohl Restrisiko bleibt? Welche *Frühwarnsignale* lösen einen Stopp aus (z. B. Exception Rate > 15 %, Audit-Finding zu Logging-Integrität)?
6. **Vorstandsvorlage** (1 Absatz): Schreiben Sie den Kernsatz, mit dem Sie den Vorstand zur Freigabe bewegen – Risiko, Nutzen, Guardrails in drei Sätzen.

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Aufgabe 10 – CoE vs. Federation – Operating Model entscheiden

L3 • Management

~ 30 min

Diskussionsaufgabe.

Ein zentralistisches *Center of Excellence* (CoE) garantiert Standards, wird aber zum Engpass. Eine *föderierte* Aufstellung (jeder Bereich macht selbst) ist schnell, erzeugt aber *Schatten-Bots* und Wildwuchs. Hybride Modelle existieren – aber sie sind *nicht einfach*: sie verschieben das Problem, ohne es zu lösen.

Arbeitsauftrag:

1. **Drei Modelle vergleichen:** *CoE-zentral, gefördert (mit Standards), Hub-and-Spoke (Hybrid)*. Tabellarisch mit fünf Kriterien: *Skalierungsgeschwindigkeit, Qualitätskonsistenz, Akzeptanz im Fachbereich, Engpass-Risiko, Audit-Tauglichkeit*.
2. **Empfehlung** (2–3 Sätze) für ein Unternehmen mit 60 Bots, 8 Bereichen, mittlerer Reife – mit Begründung.
3. **Engpass-Diagnose:** Wo ist im empfohlenen Modell der wahrscheinliche *Engpass* (Security-Review, QA, Fachfreigabe)? Wie entlasten Sie ihn *ohne* Standards zu verwässern? (Mindestens drei Hebel: z. B. Self-Service mit Templates, automatisierte Code-Checks, Reviewer-Pool, Risk-Based Routing.)
4. **Frühwarnsignale “Modell stimmt nicht mehr”:** drei messbare Signale (z. B. Anteil “Shadow Bots” > X %, Time-to-Production > 8 Wochen, Audit-Findings > 3 pro Quartal).
5. **Konsequenz:** Wann *kippen* Sie ein Modell? (Faustregel in 1–2 Sätzen.)

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

[illegible]

.....

.....

.....

.....

.....

.....

Aufgabe 11 – Transferprojekt – Enterprise RPA Operating Model

L3 • Management

~ 50 min

Rolle und Ausgangslage

Ihre Rolle: *Head of Automation CoE / COO* einer wachsenden Organisation.

Auftrag: Ein unternehmensweites *RPA Operating Model* etablieren, das Skalierung ermöglicht, aber Audit, Compliance und Security *nachweisbar* beherrscht – inklusive Change- und Kommunikationsstrategie.

Ausgangslage:

- Viele Fachbereiche, heterogene Prozesse.
- UI-Volatilität (Portale ändern sich oft).
- Budget: 300.000 €.
- Security-Kapazität knapp (2 FTE für 60 Bots).
- Kultureller Widerstand möglich (“Bots ersetzen uns”).

Arbeitsauftrag: Entwickeln Sie eine strukturierte *Entscheidungsarchitektur* – keine reine Maßnahmenliste – in 8–10 Schritten:

1. **Risk Appetite & Guardrails:** Bot-Klassifikation, Freigabestufen, SoD-Regeln, Logging/Retention Standard, Human-in-the-Loop-Pflichten.
2. **Operating Model:** CoE / federated / hybrid – Rollen, RACI, Eskalation, Incident- und Problem-Management für Bots.
3. **Quality & Release Management:** Teststrategie, UAT, Change-Prozess, Versionierung, Rollback, Monitoring-Katalog.
4. **Exception Governance:** Codes, Playbooks, KPI-Steuerung (Exception Rate, MTTR, Rework), Root Cause Reviews.
5. **Security-by-Design Blueprint:** Identity & Access, Secrets, Logging Integrity, Zugriff auf PII, Third-Party-/Portal-Risiken.
6. **Change & Enablement:** Stakeholder-Plan, Trainingsrollen, Kommunikationsnarrativ, Erfolgsmessung (Akzeptanz, Skill Shift).
7. **Zwei Entscheidungen unter Unsicherheit** mit Annahme, verworfener Alternative, Frühwarnsignal:
 - *CoE vs. Föderation:* Welche Variante wählen Sie – und welche Shadow-Bot-Rate / Incident-Rate triggert eine Korrektur?
 - *Fast Track Grenze:* Welche Bot-Klasse darf schnell in Prod – und ab welchen KPI-Schwellen wird gestoppt?
8. **Anschluss an Strategie:** Warum lohnt sich das aus Sicht der Geschäftsleitung? Mindestens drei Argumente (Compliance-Risiko, Skalierbarkeit, Time-to-Value).

Bewertungskriterien (Senior-Level): Pragmatismus unter Restriktionen · Klarheit der Verantwortlichkeiten · Anschlussfähigkeit an Risk & Audit · Reife des Entscheidens unter Unsicherheit · Wirkung von “Bots kontrollieren” zu “verantwortbares Automationssystem führen”.

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

[illegible]

.....

.....

.....

.....

.....

.....

.....

Abschluss

Sie haben alle elf Aufgaben zu Tag 12 bearbeitet. Vergleichen Sie nun Ihre Antworten mit dem *Lösungsheft Tag 12*.

Was Sie jetzt können sollten

- Bot-Lifecycle, Governance-Rollen und nicht verhandelbare Standards benennen und einsetzen.
- Audit-Trail-Anforderungen (Wer/Was/Wann/Womit/Ergebnis) sauber operationalisieren – inkl. Aufbewahrung und Access-Regeln.
- Exception Handling als ROI-Hebel begreifen (Codes, Playbooks, SLAs, MTTR-Steuerung).
- Security-by-Design für Bots als “privilegierte Mitarbeiter” entwerfen (Least Privilege, SoD, Vault, PII).
- Change Management nicht “nachreichen”, sondern als Teil des Designs verankern (Rollenwandel, Trainingspfad, Champions).
- Bot-Klassifikation und Risk Appetite als Entscheidungsbasis nutzen – statt jeden Fall einzeln zu verhandeln.
- CoE vs. Föderation *begründet* wählen, Engpässe antizipieren, Frühwarnsignale messen.
- Ein Enterprise-Operating-Model als Entscheidungsarchitektur formulieren – nicht als Werkzeugkasten.